

Day 19 – False Positives & Detection Tuning

False Positives Fundamentals

A **false positive (FP)** occurs when legitimate activity is incorrectly identified as malicious. While detections should identify real threats, overly broad rules can generate excessive alerts, leading to analyst fatigue and slower incident response.

Alert Classification

Classification	Description
True Positive (TP)	Malicious activity correctly detected.
False Positive (FP)	Legitimate activity incorrectly flagged.
True Negative (TN)	Legitimate activity correctly ignored.
False Negative (FN)	Malicious activity missed by detection.

Common Causes of False Positives

- Broad or generic detection rules
 - Legitimate administrator activity
 - Software deployment or maintenance tasks
 - Security tools and vulnerability scanners
 - Backup and monitoring software
 - Missing user, device, or network context
-

Detection Tuning

Detection tuning improves alert quality by reducing unnecessary alerts while maintaining strong detection coverage.

Recommended Techniques

- Allowlist trusted users, servers, and enterprise tools.
 - Apply thresholds instead of alerting on single events.
 - Use command-line analysis instead of process names alone.
 - Establish user and device behavior baselines.
 - Correlate authentication, process, network, and persistence events.
 - Continuously review and refine detection rules.
-

Practical Exercise Findings

- Compared **TP, FP, TN, and FN**, understanding their impact on SOC operations.
 - Analyzed false positives involving **PowerShell, Certutil, RDP, Scheduled Tasks, and Windows Defender**.
 - Improved detections using:
 - Administrative allowlists
 - Behavioral baselines
 - Command-line analysis
 - Event thresholds
 - Multi-event correlation
 - Learned that **tool execution alone is insufficient**; analysts should validate process lineage, user context, and related events before escalating an alert.
-

Investigation Scenario

Routine business activity generated alerts for **PowerShell, Certutil, RDP, Scheduled Tasks**, and **Windows Defender**. Investigation showed these actions were performed by trusted administrators, approved software deployment systems, or built-in security tools.

Although each alert appeared suspicious individually, supporting evidence confirmed they were **likely false positives**. The exercise reinforced that detection decisions should rely on **behavioral context and correlated evidence**, not individual tool execution.

Detection Engineering Best Practices

- Validate alerts using user, process, network, and system context.
 - Correlate multiple telemetry sources.
 - Focus on attacker behavior rather than tool execution.
 - Review and tune detections regularly.
 - Document tuning decisions and rule changes.
-

MITRE ATT&CK

- **T1059.001** – PowerShell
- **T1218** – System Binary Proxy Execution (Certutil)
- **T1021.001** – Remote Desktop Protocol
- **T1053.005** – Scheduled Task/Job
- **T1110** – Brute Force (*when applicable*)

- **T1078** – Valid Accounts (*when applicable*)
-

Key Takeaway

Effective SOC operations depend on accurate alert classification rather than simply generating more alerts. Behavioral analysis, contextual validation, and multi-event correlation help distinguish legitimate administrative activity from genuine attacks, reducing false positives while maintaining strong security visibility.